



NIST Internal Report
NIST IR 8374r1

Ransomware Risk Management:

A Cybersecurity Framework 2.0 Community Profile

Murugiah Souppaya
William C. Barker
William Fisher
Karen Kent

This publication is available free of charge from:
<https://doi.org/10.6028/NIST.IR.8374r1>

NIST Internal Report
NIST IR 8374r1

Ransomware Risk Management:
A Cybersecurity Framework 2.0 Community Profile

Murugiah Souppaya*
Computer Security Division
Information Technology Laboratory

William Fisher
Applied Cybersecurity Division
Information Technology Laboratory

William C. Barker
Guest Researcher
Information Technology Laboratory

Karen Kent
Trusted Cyber Annex

** Former employee; all work for this publication was done while at NIST.*

This publication is available free of charge from:
<https://doi.org/10.6028/NIST.IR.8374r1>

June 2026



U.S. Department of Commerce
Howard Lutnick, Secretary

National Institute of Standards and Technology
Arvind Raman, NIST Director and Under Secretary of Commerce for Standards and Technology

Certain equipment, instruments, software, or materials, commercial or non-commercial, are identified in this paper in order to specify the experimental procedure adequately. Such identification does not imply recommendation or endorsement of any product or service by NIST, nor does it imply that the materials or equipment identified are necessarily the best available for the purpose.

There may be references in this publication to other publications currently under development by NIST in accordance with its assigned statutory responsibilities. The information in this publication, including concepts and methodologies, may be used by federal agencies even before the completion of such companion publications. Thus, until each publication is completed, current requirements, guidelines, and procedures, where they exist, remain operative. For planning and transition purposes, federal agencies may wish to closely follow the development of these new publications by NIST.

Organizations are encouraged to review all draft publications during public comment periods and provide feedback to NIST. Many NIST cybersecurity publications, other than the ones noted above, are available at <https://csrc.nist.gov/publications>.

NIST Technical Series Policies

[Copyright, Use, and Licensing Statements](#)

[NIST Technical Series Publication Identifier Syntax](#)

Publication History

Approved by the NIST Editorial Review Board on 2026-04-30.

Supersedes NIST IR 8374 (February 2022) <https://doi.org/10.6028/NIST.IR.8374>

How to Cite this NIST Technical Series Publication

Souppaya M, Barker WC, Fisher W, Scarfone K. (2026) Ransomware Risk Management: A Cybersecurity Framework 2.0 Community Profile. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Internal Report (IR) NIST IR 8374r1. <https://doi.org/10.6028/NIST.IR.8374r1>

Author ORCID iDs

Murugiah Souppaya: 0000-0002-8055-8527

William C. Barker: 0000-0002-4113-8861

William Fisher: 0009-0004-7569-5668

Karen Scarfone: 0000-0001-6334-9486

Contact Information

ransomware@nist.gov

National Institute of Standards and Technology

Attn: Applied Cybersecurity Division, Information Technology Laboratory

100 Bureau Drive (Mail Stop 2000) Gaithersburg, MD 20899-2000

Additional Information

Additional information about this publication is available at <https://csrc.nist.gov/pubs/ir/8374/r1/final>, including related content, potential updates, and document history.

All comments are subject to release under the Freedom of Information Act (FOIA)

Abstract

Ransomware is a type of malicious attack where attackers encrypt an organization's data and demand payment to restore access. Attackers may also steal an organization's information and demand an additional payment in return for not disclosing the information to authorities, competitors, or the public. This Cybersecurity Framework (CSF) 2.0 Community Profile identifies the security outcomes from the NIST CSF 2.0 that support governing management of, identifying, protecting against, detecting, responding to, and recovering from ransomware events. The Profile can be used as a guide to managing the risk of ransomware events. That includes helping to gauge an organization's level of readiness to counter ransomware threats and to deal with the potential consequences of events. This Profile can be leveraged in developing a ransomware countermeasure playbook.

Keywords

Cybersecurity Framework; detect; identify; protect; ransomware; recover; respond; risk; security.

Reports on Computer Systems Technology

The Information Technology Laboratory (ITL) at the National Institute of Standards and Technology (NIST) promotes the U.S. economy and public welfare by providing technical leadership for the Nation's measurement and standards infrastructure. ITL develops tests, test methods, reference data, proof of concept implementations, and technical analyses to advance the development and productive use of information technology. ITL's responsibilities include the development of management, administrative, technical, and physical standards and guidelines for the cost-effective security and privacy of information other than national security-related information in federal information systems.

Audience

This Ransomware Community Profile is intended for any organization (including industry, government, and nonprofits) that could be subject to ransomware attacks, regardless of sector or size. As the Profile helps to prioritize efforts, it could be especially valuable for smaller and less resourced organizations.

In addition, the Profile is intended for organizations that:

- are familiar with—and may have already adopted—the CSF to help manage cybersecurity risks and want to improve their risk postures by addressing ransomware threats, or
- are not familiar with the CSF but want to implement risk management frameworks to mitigate ransomware threats. Such organizations may wish to review the CSF for additional context and guidelines.

Additional Resources

NIST's National Cybersecurity Center of Excellence (NCCoE) has produced guidelines to support ransomware threat mitigation. NIST has many other resources that, while not ransomware-specific, contain valuable information about governing management of, identifying, protecting against, detecting, responding to, and recovering from ransomware events. See [Appendix A](#) for a more extensive list of NIST resources.

Patent Disclosure Notice

NOTICE: ITL has requested that holders of patent claims whose use may be required for compliance with the guidance or requirements of this publication disclose such patent claims to ITL. However, holders of patents are not obligated to respond to ITL calls for patents and ITL has not undertaken a patent search in order to identify which, if any, patents may apply to this publication.

As of the date of publication and following call(s) for the identification of patent claims whose use may be required for compliance with the guidance or requirements of this publication, no such patent claims have been identified to ITL.

No representation is made or implied by ITL that licenses are not required to avoid patent infringement in the use of this publication.

Table of Contents

1. Introduction.....	1
1.1 The Ransomware Challenge.....	1
1.2 Basic Ransomware Tips.....	2
2. The Ransomware Community Profile	4
Appendix A. Additional NIST Ransomware Resources.....	15

1. Introduction

This Ransomware Community Profile can help organizations and individuals manage the risk of ransomware events. That includes helping gauge an organization's readiness to counter ransomware threats and to address the potential consequences of events. The Profile can also be used to identify opportunities to improve cybersecurity and help thwart ransomware. It prioritizes security outcomes from the NIST Cybersecurity Framework (CSF) 2.0 [\[NIST CSWP 29\]](#) to security capabilities and measures that help to govern management of, identify, protect against, detect, respond to, and recover from ransomware events.

This Community Profile was developed in collaboration with industry to serve as a baseline of CSF outcomes that address shared interests and goals among multiple organizations. Individual organizations may use Community Profiles to create their own Organizational Profile, detailing their current and/or target cybersecurity posture in terms of the outcomes identified in the CSF. Examples of profiles can be found on the [NIST CSF website](#), along with a [template](#) for creating Organizational Profiles. The guidelines in this report address best practices rather than a set of legal or regulatory requirements.

1.1 The Ransomware Challenge

Ransomware is a type of malicious software (malware) that encrypts an organization's data and demands payment as a condition of restoring access to that data. Ransomware can also be used to steal an organization's information and demand additional payment in return for not disclosing the information to authorities, competitors, or the public. Ransomware events target the organization's data or critical infrastructure, disrupting or halting operations and posing a dilemma for management: pay the ransom and hope the attackers keep their word to restore access and not disclose data, or do not pay the ransom and attempt to restore operations themselves. The methods ransomware uses to gain access to an organization's information and systems are common to cyberattacks more broadly, but they are aimed at forcing a ransom to be paid. Techniques used to spread ransomware will continue to evolve as attackers seek new ways to pressure their victims.

Ransomware attacks differ from other cybersecurity events in which access may be surreptitiously gained to information such as intellectual property, credit card data, or personally identifiable information, and later exfiltrated for monetization. Instead, ransomware threatens an immediate and known impact on business operations. During a ransomware event, organizations may have little time to mitigate or remediate the impact, restore systems, or communicate via necessary business, partner, and public relations channels. For this reason, it is especially critical that organizations be prepared. That includes having cybersecurity governance that integrates into enterprise risk management for a holistic view and treatment of ransomware risks. Users, security and response teams, and business decision makers, should be educated about the importance of—and processes and procedures for—preventing and handling potential compromises, before they occur.

Fortunately, organizations can follow recommended steps to prepare for and reduce the potential for successful ransomware attacks. This includes the following:

- establish, communicate, and monitor ransomware risk strategy, expectations, and policy;
- identify, prioritize, and protect critical data, systems, and devices;
- detect ransomware events as early as possible (preferably before the ransomware is deployed); and
- prepare to respond to and recover from any ransomware events that do occur.

Additional NIST resources are listed in [Appendix A](#).

1.2 Basic Ransomware Tips

Ransomware remains one of the most disruptive cyber threats facing organizations today. Recognizing that not every organization has the resources to implement every measure, the following essential practices offer a foundation for protection. These steps and tips are mapped to the CSF and designed to be immediately actionable and adaptable to diverse operational environments. Not all these measures will apply to the situations of all organizations.

BASIC RANSOMWARE TIPS

Even without undertaking all the measures described in this Ransomware Community Profile, there are some basic preventive steps that an organization can take now to protect against and recover from the ransomware threat. These include:

1. Plan for Ransomware Events.

- **Establish organizational priorities and determine risk appetite** to guide the selection of ransomware mitigations that align with business needs and risks. (GV.OC-01, GV.RM-02, GV.RM-03)
- **Know your decision makers.** Determine cybersecurity roles and responsibilities to facilitate accountability and clear decision making for cybersecurity risk. (GV.RR-02)
- **Enumerate legal requirements.** Understand and manage the legal, regulatory, and contractual requirements that impact cybersecurity risks and response. (GV.OC-03)

2. Educate employees on avoiding ransomware infections.

- **Conduct regular phishing and social media simulations** to train employees not to open files or click on links from unknown sources. (PR.AT-01)
- **Educate employees on the risk of connecting personally owned devices to work networks** through annual training and regular security reminders. (PR.AT-01)
- **Create a culture of incident reporting** that avoids placing blame on employees for actions that cause cyber risks and instead empower employees by encouraging them to immediately notify security of suspected cyber events. (PR.AT-01)

3. Avoid having vulnerabilities in systems that ransomware could exploit.

- **Keep relevant systems fully patched.** Run scheduled checks to identify available patches and install these as soon as feasible. (ID.AM-02, PR.PS-01)

- **Employ zero trust principles in all networked systems.** Manage access to all network functions and segment internal networks where practical to prevent malware from proliferating among potential target systems. (PR.AA-01, PR.AA-03, PR.AA-05, PR.IR-01)
- **Allow installation and execution of authorized apps only.** Configure operating systems and/or third-party software to run only authorized applications. This can also be supported by adopting a policy for reviewing, then adding or removing authorized applications on an allow list. (PR.PS-05)
- **Inform your technology vendors of your expectations** (e.g., in contract language) that they will apply cybersecurity measures commensurate to risk that mitigate against ransomware attacks. (GV.SC-02)

4. Quickly detect and stop ransomware attacks and infections.

- **Use malware detection software, such as endpoint security solutions at all times.** Set it to automatically scan emails and flash drives. (DE.CM-09, DE.AE-02)
- **Continuously monitor** directory services (and other primary user stores) for indicators of compromise or active attack. (DE.CM-03, DE.AE-02)
- **Block access to untrusted web resources.** Use products or services that block access to server names, IP addresses, or ports and protocols that are known to be malicious or suspected to be indicators of malicious system activity. This includes using products and services that provide integrity protection for the domain component of addresses (e.g., hacker@poser.com). (ID.AM-03, DE.CM-01)

5. Make it harder for ransomware to spread.

- **Use standard user accounts** with multi-factor authentication versus accounts with administrative privileges whenever possible. (PR.AA-01, PR.AA-05)
- **Introduce authentication delays or configure automatic account lockout** as a defense against automated attempts to guess passwords. (PR.AA-01, PR.AA-05)
- **Assign and manage credential authorization** for all enterprise assets and software and periodically verify that each account has only the necessary access following the principle of least privilege. (PR.AA-05, PR.AA-06, PR.IR-01)
- **Store data in an immutable format** (so that the database does not automatically overwrite older data when new data is made available). (PR.DS-11)
- **Allow external access to internal network resources via secure virtual private network (VPN) connections only.** (PR.AA-03)

6. Make it easier to recover from a future ransomware event.

- **Make an incident response and recovery plan.** Develop, implement, and regularly exercise an incident response and recovery plan with defined roles and strategies for decision making. This can be part of a continuity of operations plan. The plan should identify mission-critical and other business-essential services to enable recovery prioritization, and business continuity plans for those critical services. This should include a strategy for out of band communications should normal business communication channels be disrupted by the ransomware event. (RS.MA-01, RS.CO-02, RC.RP-01, RC.CO-03)
- **Back up data, secure backups, and test restoration.** Carefully plan, implement, and test a data backup and restoration strategy—and secure and isolate backups of important data. (PR.DS-11, RC.RP-03)
- **Keep your contacts.** Maintain an up-to-date list of internal and external contacts for ransomware attacks, including law enforcement, legal counsel, and incident response resources. (RS.CO-02, RS.CO-03, RC.CO-03, RC.CO-04)
- **Consider Ransomware Insurance.** Cyber insurance, especially for small and medium size businesses, can help alleviate the financial pressure of a ransomware event, helping to keep organizations operational during response and recovery. (GV.RM-03)

2. The Ransomware Community Profile

The Ransomware Community Profile aligns organizations' ransomware prevention and mitigation requirements, objectives, risk appetite, and resources with the elements of the CSF. It aims to help organizations identify and prioritize opportunities for improving their security and resilience against ransomware attacks. Organizations can use this document as a guide for profiling the state of their own readiness. Doing so will help them determine their current "organizational profile" or state and set a "target organizational profile" to identify gaps.

[Table 1](#) below identifies Categories and Subcategories from CSF 2.0 that are particularly relevant to mitigating ransomware risk. The first two columns list these Categories and Subcategories which organizations may use as priority target outcomes for ransomware risk management programs. The third column briefly explains how each Subcategory helps to govern management of, identify, protect against, detect, respond to, and recover from ransomware events.

Organizations are encouraged to include the full set of CSF 2.0 Subcategories for their cybersecurity risk management programs. The selection of Subcategories highlighted in this document is specific to ransomware risks. Organizations should account for their own unique environments and risk management strategies when using this profile.

NIST and other organizations have produced a [suite of online resources](#) that help organizations understand, adopt, and use the CSF, including Informative References, Implementation Examples, and Quick Start Guides.

The six Cybersecurity Framework Functions used to organize the Categories are:

- **GOVERN (GV)** — *The organization's cybersecurity risk management strategy, expectations, and policy are established, communicated, and monitored.* The GOVERN Function provides outcomes to inform what an organization may do to achieve and prioritize the outcomes of the other five Functions in the context of its mission and stakeholder expectations. Governance activities are critical for incorporating cybersecurity into an organization's broader enterprise risk management (ERM) strategy. GOVERN addresses an understanding of organizational context; the establishment of cybersecurity strategy and cybersecurity supply chain risk management; roles, responsibilities, and authorities; policy; and the oversight of cybersecurity strategy.
- **IDENTIFY (ID)** — *The organization's current cybersecurity risks are understood.* Understanding the organization's assets (e.g., data, hardware, software, systems, facilities, services, people), suppliers, and related cybersecurity risks enables an organization to prioritize its efforts consistent with its risk management strategy and the mission needs identified under GOVERN. This Function also includes identifying improvement opportunities for the organization's policies, plans, processes, procedures, and practices that support cybersecurity risk management, to inform efforts across all six Functions.

- **PROTECT (PR)** — *Safeguards to manage the organization’s cybersecurity risks are used.* Once assets and risks are identified and prioritized, PROTECT supports the ability to secure those assets to prevent or reduce the likelihood and impact of adverse cybersecurity events, as well as to increase the likelihood and impact of taking advantage of opportunities. Outcomes covered by this Function include identity management, authentication, and access control; awareness and training; data security; platform security (i.e., securing the hardware, software, and services of physical and virtual platforms); and the resilience of technology infrastructure.
- **DETECT (DE)** — *Possible cybersecurity attacks and compromises are found and analyzed.* DETECT enables the timely discovery and analysis of anomalies, indicators of compromise, and other potentially adverse events that may indicate that cybersecurity attacks and incidents are occurring. This Function supports incident response and recovery activities.
- **RESPOND (RS)** — *Actions regarding a detected cybersecurity incident are taken.* RESPOND supports the ability to contain the effects of cybersecurity incidents. Outcomes within this Function cover incident management, analysis, mitigation, reporting, and communication.
- **RECOVER (RC)** — *Assets and operations affected by a cybersecurity incident are restored.* RECOVER supports the timely restoration of normal operations to reduce the effects of cybersecurity incidents and enable appropriate communication during recovery efforts.

The CSF 2.0 outcomes included in [Table 1](#) also map to controls, requirements, and recommendations of other security standards and guidelines documents. Examples include NIST’s Special Publication 800-53; ISO/IEC standards on information, security, cybersecurity, and privacy protection; and industry consensus standards. The Cybersecurity and Privacy Reference Tool ([CPRT](#)) highlights the reference data from NIST publications without the constraints of PDF files. This enables stakeholders to interactively browse, search, and export the data in a structured format that is human- and machine-consumable. For example, you can use the search tool to locate reference data in each publication and then download the reference data for each publication in MS Excel or JavaScript Object Notation (JSON). The [Online Informative Reference Catalog](#) contains the reference data, including Informative References and Derived Relationship Mappings (DRMs), for the National Online Informative References (OLIR) Program.

Table 1. Ransomware Community Profile

CSF 2.0 Category	CSF 2.0 Outcome	Ransomware Application
Organizational Context (GV.OC): The circumstances—mission, stakeholder expectations, dependencies, and legal, regulatory, and contractual requirements—surrounding the organization’s cybersecurity risk management decisions are understood	GV.OC-01: The organizational mission is understood and informs cybersecurity risk management	Priorities for organizational mission, objectives, and activities are established and communicated. Understanding priorities for organizational objectives and activities is needed to support contingency planning for future ransomware events and emergency response and recovery actions. For example, the most critical enterprise information and operational activities or functions might be given the highest priority for backup as well as for access management.
Organizational Context (GV.OC)	GV.OC-02: Internal and external stakeholders are understood, and their needs and expectations regarding cybersecurity risk management are understood and considered	Understanding the needs and expectations of internal and external stakeholders with respect to cybersecurity risk management is needed to support contingency planning for future ransomware events and emergency response and recovery actions (e.g., notification requirements).
Organizational Context (GV.OC)	GV.OC-03: Legal, regulatory, and contractual requirements regarding cybersecurity—including privacy and civil liberties obligations—are understood and managed	Understanding legal and regulatory requirements regarding cybersecurity and privacy is necessary for organizational cybersecurity policy development and for establishing priorities in contingency planning for responses to and recovery from future ransomware events.

CSF 2.0 Category	CSF 2.0 Outcome	Ransomware Application
Risk Management Strategy (GV.RM): The organization's priorities, constraints, risk tolerance and appetite statements, and assumptions are established, communicated, and used to support operational risk decisions	GV.RM-02: Risk Appetite and risk tolerance statements are established, communicated, and maintained	A documented and communicated understanding of risk appetite and tolerance helps organizations make clear and justifiable decisions during response and recovery from a ransomware event.
Risk Management Strategy (GV.RM)	GV.RM-03: Cybersecurity risk management activities and outcomes are included in enterprise risk management processes	Ransomware risks must be factored into organizational risk management governance to support establishment of adequate organizational cybersecurity policies. This includes factors that might help transfer risk such as cyber insurance.
Roles, Responsibilities, and Authorities (GV.RR): Cybersecurity roles, responsibilities, and authorities to foster accountability, performance assessment, and continuous improvement are established and communicated	GV.RR-02: Roles, responsibilities, and authorities related to cybersecurity risk management are established, communicated, understood, and enforced	Because ransomware events often result in the immediate loss of business functionality, organizations face extreme pressure to recover business functions quickly. Effective ransomware mitigation and response requires that everyone in the organization understand their role, responsibility, and authority prior to a ransomware event.
Cybersecurity Supply Chain Risk Management (GV.SC): Cyber supply chain risk management processes are identified, established, managed, monitored, and improved by organizational stakeholders	GV.SC-02: Cybersecurity roles and responsibilities for suppliers, customers, and partners are established, communicated, and coordinated internally and externally	Many ransomware events are enabled by some member of the workforce or a third-party stakeholder taking an intentional or inadvertent action that enables infiltration by criminals or other unauthorized parties. It's important to understand roles and responsibilities for preventing ransomware infections and the associated responsibilities with response and recovery actions.

CSF 2.0 Category	CSF 2.0 Outcome	Ransomware Application
Cybersecurity Supply Chain Risk Management (GV.SC)	GV.SC-08: Relevant suppliers and other third parties are included in incident planning, response, and recovery activities	Ransomware contingency planning should be coordinated with suppliers and third-party providers, and planning should include provision for testing of planned activities.
Asset Management (ID.AM): Assets (e.g., data, hardware, software, systems, facilities, services, people) that enable the organization to achieve business purposes are identified and managed consistent with their relative importance to organizational objectives and the organization's risk strategy	ID.AM-02: Inventories of software, services, and systems managed by the organization are maintained	It is important to update your software as soon as practical after updates become available to remove vulnerabilities that attackers can take advantage of to infiltrate your systems using ransomware. Also, some software utilities and applications contain known vulnerabilities used for intrusion. Software inventories may track elements such as software name and version, devices where it's currently installed, last patch date, and current known vulnerabilities. This information supports scheduling updates and removing vulnerable utilities and applications.
Asset Management (ID.AM)	ID.AM-03: Representations of the organization's authorized network communication and internal and external network data flows are maintained	Understanding organizational communications and data flows is needed as preparation for responding to future ransomware events. In addition to enabling assignment of responsibilities, knowing the connections and flows helps to enumerate what information or processes are at risk based on the identified criminal infiltration. Cataloging connections to external information systems is important for planning communications to partners and possible actions to temporarily disconnect from external systems in response to ransomware events. Identifying these connections will also help organizations plan security control implementation and identify areas where controls may be shared with third parties. Note that ransomware attacks can disable common communication channels (e.g., email). It is essential that planning include means for communication with staff and partners in the event of such attacks.
Asset Management (ID.AM)	ID.AM-05: Assets are prioritized based on classification, criticality, resources, and impact on the mission	Prioritization of data and software based on classification, criticality, and impact on mission is essential to understanding the true scope and impact of ransomware events and is an important factor in prioritizing security controls and response and recovery efforts.

CSF 2.0 Category	CSF 2.0 Outcome	Ransomware Application
Risk Assessment (ID.RA): The cybersecurity risk to the organization, assets, and individuals is understood by the organization	ID.RA-01: Vulnerabilities in assets are identified, validated, and recorded	Identifying and documenting the vulnerabilities of organizational assets supports development and prioritization of planning to mitigate or eliminate those vulnerabilities as well as contingency planning for evaluation of and responses to future ransomware events.
Risk Assessment (ID.RA)	ID.RA-04: Potential impacts and likelihoods of threats exploiting vulnerabilities are identified and recorded	Understanding the business impacts of potential ransomware events is needed to support cybersecurity cost-benefit analyses as well as to establish priorities for activities included in ransomware contingency plans for response and recovery. Understanding the potential business impacts also supports emergency response decisions in the event of a ransomware attack.
Risk Assessment (ID.RA)	ID.RA-06: Risk responses are chosen, prioritized, planned, tracked, and communicated	The expense associated with response to and recovery from ransomware events is materially affected by the effectiveness of contingency planning of responses to projected risks.
Risk Assessment (ID.RA)	ID.RA-09: The authenticity and integrity of hardware and software are assessed prior to acquisition and use	Software of unknown or unreliable provenance can contain malware or otherwise be subject to exploitation by bad actors.
Improvement (ID.IM): Improvements to organizational cybersecurity risk management processes, procedures and activities are identified across all CSF Functions	ID.IM-04: Incident response plans and other cybersecurity plans that affect operations are established, communicated, maintained, and improved	Response and recovery plans should include response to and recovery from future ransomware events. Ransomware response and recovery plans should be tested periodically to ensure that risk and response assumptions and processes are current with respect to evolving ransomware threats.

CSF 2.0 Category	CSF 2.0 Outcome	Ransomware Application
Identity Management, Authentication, and Access Control (PR.AA): Access to physical and logical assets is limited to authorized users, services, and hardware and managed commensurate with the assessed risk of unauthorized access	PR.AA-01: Identities and credentials for authorized users, services, and hardware are managed by the organization	Because ransomware attacks often start with credential compromise, proper credential management is an essential mitigation. The type of credential and how credentials are issued, managed, revoked and recovered are critical considerations for preventing credential compromise that could lead to ransomware events.
Identity Management, Authentication, and Access Control (PR.AA)	PR.AA-03: Users, services, and hardware are authenticated	Most ransomware attacks are conducted through network connections, and because social engineering-based compromise of passwords is a major source of compromise, authentication of identities using phishing-resistant multi-factor authentication and the implementation of zero trust architectures are strongly recommended.
Identity Management, Authentication, and Access Control (PR.AA)	PR.AA-05: Access permissions, entitlements, and authorizations are defined in a policy, managed, enforced, and reviewed, and incorporate the principles of least privilege and separation of duties	Many ransomware intrusions occur through the compromise of user credentials or invoking processes that should not be authorized to have privileged access to the process that is being infiltrated.
Identity Management, Authentication, and Access Control (PR.AA)	PR.AA-06: Physical access to assets is managed, monitored, and enforced commensurate with risk	Although most ransomware attacks are conducted remotely, managing and protecting physical access does protect against insider attacks. This includes protection against others, including family members, accessing physical devices and intentionally or inadvertently degrading the logical access protections associated with the devices.

CSF 2.0 Category	CSF 2.0 Outcome	Ransomware Application
Awareness and Training (PR.AT): The organization's personnel are provided with cybersecurity awareness and training so that they can perform their cybersecurity-related tasks	PR.AT-01: Personnel are provided with awareness and training so that they possess the knowledge and skills to perform general tasks with cybersecurity risks in mind	Most ransomware attacks are made possible by users who engage in unsafe practices, administrators who implement insecure configurations, or developers who have insufficient security training.
Data Security (PR.DS): Data are managed consistent with the organization's risk strategy to protect the confidentiality, integrity, and availability of information	PR.DS-11: Backups of data are created, protected, maintained, and tested	Regular backups that are maintained and tested are essential to timely and recovery from ransomware events. Backups should have a copy stored offline or otherwise in a manner that prevents access to them by the attacker or compromise by ransomware.
Platform Security (PR.PS): The hardware, software (e.g., firmware, operating systems, applications), and services of physical and virtual platforms are managed consistent with the organization's risk strategy to protect their confidentiality, integrity, and availability	PR.PS-01: Configuration management practices are established and applied	Proper configuration change processes can help to enforce timely security updates to software, maintain necessary security configuration settings, and discourage replacement of code with products that contain malware or don't satisfy access management policies. This CSF outcome reduces an attacker's opportunities to exploit system vulnerabilities, thus protecting against ransomware attacks.
Platform Security (PR.PS)	PR.PS-02: Software is maintained, replaced, and removed commensurate with risk	Old versions of software may contain vulnerabilities of which ransomware actors are aware and can exploit. Software updates should be promptly installed, and software that is no longer supported should be replaced.
Platform Security (PR.PS)	PR.PS-04: Log records are generated and made available for continuous monitoring	Availability of audit/log records can assist in proactive anomaly detection as well as forensics in support of recovery and response processes.

CSF 2.0 Category	CSF 2.0 Outcome	Ransomware Application
Platform Security (PR.PS)	PR.PS-05: Installation and execution of unauthorized software are prevented	Software of unknown or unreliable provenance can contain malware or other vulnerabilities that can be exploited by a ransomware actor. This objective includes implementing protective technologies such as those that prevent malware installation, use allowlisting/denylisting protections for executables, and block access to known-malicious domains.
Technology Infrastructure Resilience (PR.IR): Security architectures are managed with the organization's risk strategy to protect asset confidentiality, integrity, and availability, and organizational resilience	PR.IR-01: Networks and environments are protected from unauthorized logical access and usage	Most ransomware attacks are executed remotely. Protection of network connections can include processes as simple as password protection of Wi-Fi connections to personal computers and firewalls. In general, use of zero-trust network principles is encouraged.
Continuous Monitoring (DE.CM): Assets are monitored to find anomalies, indicators of compromise, and other potentially adverse events	DE.CM-01: Networks and network services are monitored to find potentially adverse events	Network monitoring may sometimes detect intrusions before malicious code can be inserted or large volumes of information exfiltrated.
Continuous Monitoring (DE.CM)	DE.CM-03: Personnel activity and technology usage are monitored to find potentially adverse events	Monitoring personnel activity can sometimes detect insider threats or insecure staff practices, and thwart potential ransomware events. Monitoring can also be used to find unusual patterns of usage, like someone logging on from another country. Both network and endpoint detection tools can assist this monitoring.
Continuous Monitoring (DE.CM):	DE.CM-06: External service provider activities and services are monitored to find potentially adverse events	Ransomware can be introduced intentionally or inadvertently by external service providers, especially where remote maintenance takes place. Monitoring can detect exploitable vulnerabilities before ransomware actors take advantage of them.
Continuous Monitoring (DE.CM):	DE.CM-09: Computing hardware and software, runtime environments, and their data are monitored to find potentially adverse events	Often malicious code is not immediately executed. There may be time between its insertion and its activation to detect it before the ransomware attack is executed.

CSF 2.0 Category	CSF 2.0 Outcome	Ransomware Application
Adverse Event Analysis (DE.AE): Anomalies, indicators of compromise, and other potentially adverse events are analyzed to characterize the events and detect cybersecurity incidents	DE.AE-02: Potentially adverse events are analyzed to better understand associated activities	Identifying the cause of potentially adverse behaviors can prevent or mitigate attacks. For example, receipt of data from unknown sources or sudden slowing of response times may indicate attempts to insert malware or exfiltrate information. Unknown mail headers can be clicked on to provide additional sender information and reveal suspicious senders. Terminating connections can abort exfiltration. Data center operations can undertake forensics activities to ascertain the nature and extent of attacks.
Adverse Event Analysis (DE.AE)	DE.AE-04: The estimated impact and scope of adverse events are understood	Determining the impact of events can inform response and recovery priorities to include supporting a cost-benefit analysis when deciding if a ransom should be paid.
Incident Management (RS.MA): Responses to detected cybersecurity incidents are managed	RS.MA-01: The incident response plan is executed in coordination with relevant third parties once an incident is declared	Immediate execution of the response plan is necessary to stop any continuing exfiltration of data, stem the spread of an infection to other systems and networks, and initiate pre-emptive messaging.
Incident Response Reporting and Communication (RS.CO): Response activities are coordinated with internal and external stakeholders as required by laws, regulations, or policies	RS.CO-02: Internal and external stakeholders are notified of incidents	Response to ransomware events include both technical and business responses. An efficient response requires legal, regulatory, and contractual requirements are considered when communicating about a ransomware incident.
Incident Response Reporting and Communication (RS.CO)	RS.CO-03: Information is shared with designated internal and external stakeholders	Information sharing priorities include stemming the spread of an infection to other systems and networks as well as pre-emptive messaging. Information sharing may also yield forensic benefits and reduce profitability of ransomware attacks.
Incident Mitigation (RS.MI): Activities are performed to prevent expansion of an event and mitigate its effects	RS.MI-01: Incidents are contained	Immediate action must be taken to minimize the damage to systems and data, to prevent the spread of infection to other systems and networks, and to minimize the impact on the mission or business.

CSF 2.0 Category	CSF 2.0 Outcome	Ransomware Application
Incident Mitigation (RS.MI):	RS.MI-02: Incidents are eradicated	This is necessary to minimize the probability of future successful ransomware attacks and to restore confidence among stakeholders.
Incident Recovery Plan Execution (RC.RP): Restoration activities are performed to ensure operational availability of systems and services affected by cybersecurity incidents	RC.RP-01: The recovery portion of the incident response plan is executed once initiated from the incident response process	Immediate initiation of the recovery plan can restore business function and cut losses.
Incident Recovery Plan Execution (RC.RP)	RC.RP-02: Recovery actions are selected, scoped, prioritized, and performed	Recovery actions are necessary to restore mission effectiveness and business reputation.
Incident Recovery Plan Execution (RC.RP)	RC.RP-03: The integrity of backups and other restoration assets is verified before using them for restoration	It is important to verify the integrity of backups to ensure their efficacy for use in recovering from a ransomware event.
Incident Recovery Communication (RC.CO): Restoration activities are coordinated with internal and external parties	RC.CO-03: Recovery activities and progress in restoring operational capabilities are communicated to designated internal and external stakeholders	Communication regarding the recovery progress is necessary to minimize the business impact and to restore confidence among stakeholders.
Incident Recovery Communication (RC.CO)	RC.CO-04: Public updates on incident recovery are shared using approved methods and messaging	Public updates help minimize the business impact and restore confidence among stakeholders.

Appendix A. Additional NIST Ransomware Resources

In addition to other resources cited in this document, NIST's National Cybersecurity Center of Excellence (NCCoE) has produced additional guidelines to support ransomware threat mitigation. These include:

- NIST Special Publication (SP) 1800-26, *Data Integrity: Detecting and Responding to Ransomware and Other Destructive Events* addresses how an organization can handle an attack when it occurs and what capabilities it needs to have in place to detect and respond to destructive events. Available at <https://csrc.nist.gov/pubs/sp/1800/26/final>.
- NIST SP 1800-25, *Data Integrity: Identifying and Protecting Assets Against Ransomware and Other Destructive Events* addresses how an organization can work before an attack to identify its assets and potential vulnerabilities and remedy the discovered vulnerabilities to protect these assets. Available at <https://csrc.nist.gov/pubs/sp/1800/25/final>.
- NIST SP 1800-11, *Data Integrity: Recovering from Ransomware and Other Destructive Events* addresses approaches for recovery should a data integrity attack be successful. Available at <https://csrc.nist.gov/pubs/sp/1800/11/final>.
- Protecting Data from Ransomware and Other Data Loss Events: A Guide for Managed Service Providers to Conduct, Maintain, and Test Backup Files is a guide to help managed service providers (MSPs) improve their recovery from ransomware attacks. Available at <https://csrc.nist.gov/pubs/other/2020/04/24/protecting-data-from-ransomware-and-other-data-loss/final>.

NIST has many other resources that, while not ransomware-specific, contain valuable information about identifying, protecting against, detecting, responding to, and recovering from ransomware events. Several are highlighted below. For a more complete list of resources, visit NIST's Ransomware Protection and Response site at <https://csrc.nist.gov/ransomware>.

- Improving the security of telework, remote access, and bring-your-own-device (BYOD) technologies:
 - NIST SP 800-46 Revision 2, *Guide to Enterprise Telework, Remote Access, and Bring Your Own Device (BYOD) Security* available at <https://csrc.nist.gov/pubs/sp/800/46/r2/final>
- Patching software to eliminate vulnerabilities:
 - NIST SP 800-40 Revision 4, *Guide to Enterprise Patch Management Technologies* available at <https://csrc.nist.gov/pubs/sp/800/40/r4/final>
- Implementing a zero-trust architecture to mitigate ransomware threats:
 - NIST SP 800-207, *Zero Trust Architecture* available at <https://csrc.nist.gov/pubs/sp/800/207/final>
 - NIST SP 1800-28, *Data Confidentiality: Identifying and Protecting Assets Against Data Breaches* available at <https://csrc.nist.gov/pubs/sp/1800/28/final>

- NIST SP 1800-29, Data Confidentiality: Detect, Respond to, and Recover from Data Breaches available at <https://csrc.nist.gov/pubs/sp/1800/29/final>
 - NIST SP 1800-35, *Implementing a Zero Trust Architecture* available at <https://csrc.nist.gov/pubs/sp/1800/35/final>
- Finding low-level guidelines on securely configuring software to eliminate vulnerabilities:
 - NIST SP 800-70 Revision 4, *National Checklist Program for IT Products: Guidelines for Checklist Users and Developers* available at <https://csrc.nist.gov/pubs/sp/800/70/r5/final>
- Implementing Secure DNS:
 - NIST SP 800-81 Revision 3, *Secure Domain Name System (DNS) Deployment Guide* available at <https://csrc.nist.gov/pubs/sp/800/81/r3/final>
- Integrating Cyber Risk into overall Business Risk:
 - NIST IR 8286r1 Integrating Cybersecurity and Enterprise Risk Management (ERM) available at <https://csrc.nist.gov/pubs/ir/8286/r1/final>